

医療AIプラットフォーム セキュリティ対策詳細資料

AWS Well-Architected Framework準拠。

3省2ガイドラインに対応した、高可用性かつセキュアなインフラストラクチャ設計仕様書。



Security First

ゼロトラスト / 多層防御



High Availability

SLA 99.9% / Multi-AZ



Compliance

医療情報ガイドライン準拠

セキュリティ対策の全体像

詳細アジェンダ

- 01 システム構成とセキュリティレイヤー
- 02 ネットワークセキュリティ (VPC/SG)
- 03 WAF設定詳細 (OWASP対応)
- 04 暗号化対策 (転送時 / 保存時)
- 05 IAMアクセス制御 (Least Privilege)
- 06 監査ログ・監視体制・コンテナ対策
- 07 医療データコンプライアンス (3省2)
- 08 インシデント対応 & チェックリスト

◎ 設計原則 (Design Principles)

最小権限の原則



IAMやSG設定において、必要最小限の権限と通信のみを許可する。

ゼロトラスト



境界防御だけでなく、内部通信の暗号化や認証を徹底する。

証跡の完全性



全操作ログ・通信ログを改ざん不可能な状態で長期保存する。

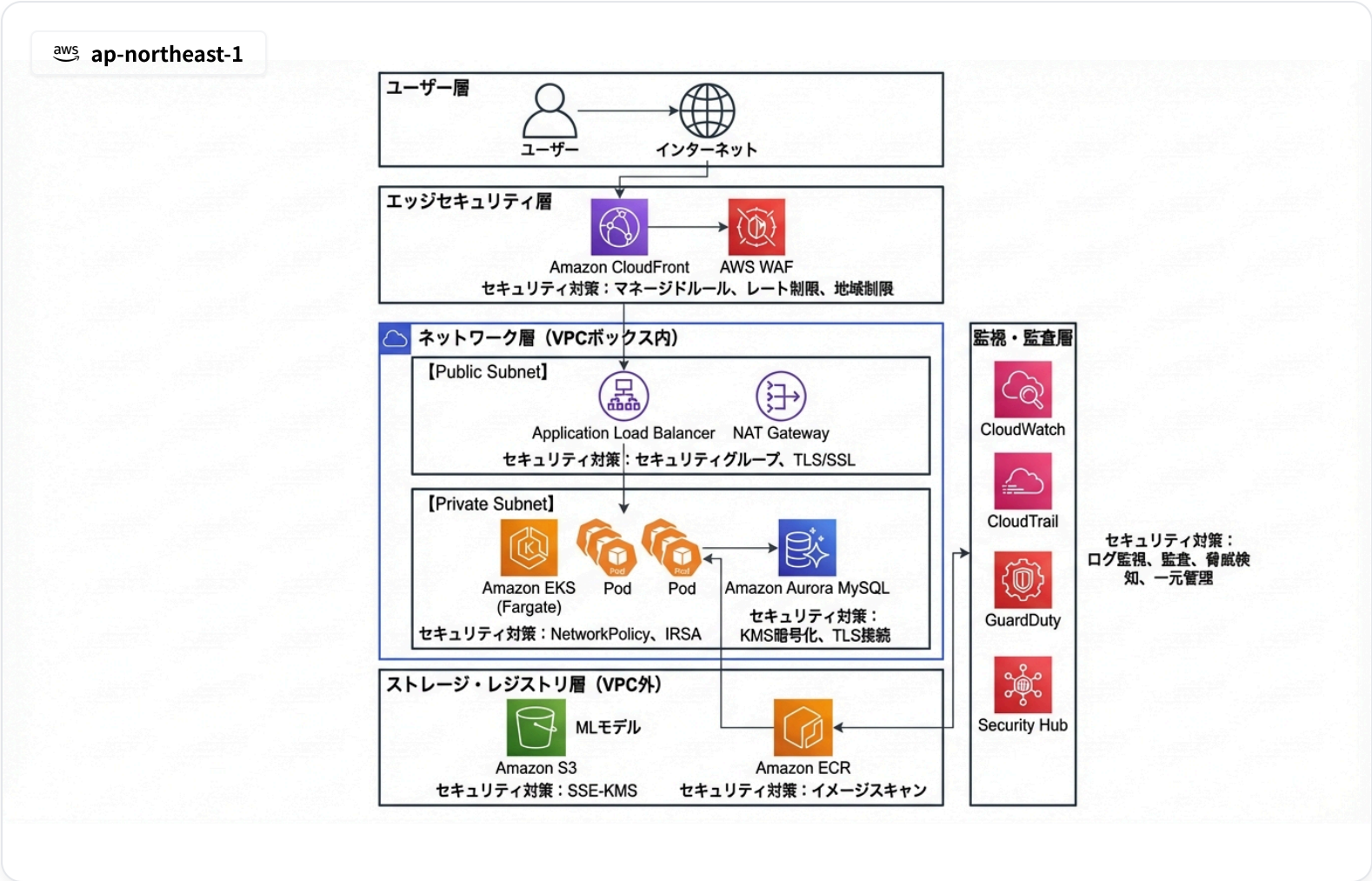
セキュリティの自動化



GuardDuty等の検知と自動修復、IaCによる構成管理を行う。

システム構成とセキュリティレイヤー

Defense in Depth (多層防御) アプローチ



🌐 エッジセキュリティ層

WAF/CDN

CloudFront + WAFによるDDoS対策とWeb攻撃遮断。

- マネージドルール (OWASP Top 10)
- 地域制限 (Geo-blocking)
- レートベース制限

🏠 ネットワーク層

VPC/SG

VPC内部の論理的隔離と通信制御。

- Public/Privateサブネット分離
- セキュリティグループによるホワイトリスト制御
- VPC Flow Logsによる全トラフィック記録

📦 アプリケーション層

EKS/App

コンテナ実行環境と認証・認可。

- IRSA (IAM Roles for Service Accounts)
- Pod Security Admission
- 秘密情報の分離 (Secrets Manager)

🗄 データ層

DB/Storage

データの暗号化と整合性保護。

- 保存時の暗号化 (KMS/CMK)
- 転送時の暗号化 (TLS 1.2+)
- 自動バックアップと監査ログ

ネットワークセキュリティ詳細

VPC設計、セキュリティグループ、およびトラフィック監査

VPC設計とセグメンテーション

ネットワークを論理的に分割し、リソースの役割に応じたアクセス制御を適用。本番環境は3つのアベイラビリティゾーン（AZ）に跨る冗長構成を採用。

- **Public Subnet:** インターネット境界。ALBとNAT Gatewayのみ配置し、外部からの直接アクセスを最小化。
- **Private Subnet:** アプリケーションとデータ層。インターネットからの直接接続を遮断し、NAT経由のOutboundのみ許可。

多層防御アプローチ

ステートフルなセキュリティグループ（SG）とステートレスなネットワークACL（NACL）を組み合わせ、意図しない通信をブロック。

- ✓ セキュリティグループの連鎖（SG Chaining）により、IPアドレスではなく論理グループでの許可を実施。
- ✓ NACLによる明示的な拒否ルールで、特定の悪意あるIPブロックやポート制限を追加。

VPC CIDR DESIGN

VPC Root

10.0.0.0/16

Public Subnets

10.0.1.0/24, 10.0.2.0/24,
10.0.3.0/24

Private Subnets (App & Data)

10.0.11.0/24, 10.0.12.0/24, 10.0.13.0/24

SECURITY GROUP RULES (INBOUND)

ALB SG

Source: 0.0.0.0/0 (Internet)

HTTPS (443) Only

EKS Node SG

Source: ALB SG

HTTP/HTTPS (80/443)

Aurora SG

Source: EKS SG

MySQL (3306)

WAF 設定詳細 (Rules & Policies)

適用ルールセット一覧

Prioritized Order (Priority 0-1000)

Priority	Rule Name	Description / Condition	Action
0	IP Whitelist Custom	管理者/社内IPからのアクセスを許可 Condition: Source IP Match	Allow
100	Geo Restriction Custom	日本国内 (JP) 以外のアクセスをブロック Condition: Geo Match != JP	Block
200	Rate Limit Custom	DDoS/ブルートフォース対策 Threshold: 1,000 req / 5 min	Block
300	AWS Common Managed	AWSManagedRulesCommonRuleSet OWASP Top 10 (XSS, CSRF, etc.)	Block
400	SQL Injection Managed	AWSManagedRulesSQLiRuleSet SQLインジェクション攻撃パターン	Block
500	Bad User Agent Custom	既知の悪性ボットやスキャナを遮断 Condition: User-Agent Match	Block

2 運用戦略

✓ 導入フェーズ:

全ルールを「Count」モードで適用し、誤検知 (False Positive) を検証・チューニング。

✓ 運用フェーズ:

検証完了後に「Block」へ移行。例外IPはホワイトリストで管理。

📄 ログ監視フロー

🛡️ WAF

➡

🔥 Firehose

➡

🗑️ S3 / CW

すべてのアクセスログ（ブロック/許可含む）をKinesis Data Firehose経由でS3へ長期保存し、CloudWatch Logs Insightsで分析。

CONFIDENTIAL / MEDICAL AI PLATFORM / P.05

暗号化対策（転送時）

エンドツーエンドでの通信経路暗号化とTLSポリシーの強化

🔗 エンドツーエンド暗号化

ユーザーからデータベースに至るまで、すべての通信経路でTLS暗号化を強制。中間者攻撃（MITM）を防ぎ、医療データの機密性を保護します。



🌸 証明書管理とポリシー強化

AWS Certificate Manager (ACM) による証明書の自動更新と、厳格なセキュリティポリシーの適用により、運用負荷を下げつつセキュリティ強度を維持。

- ✓ **TLS 1.2以上強制:** 脆弱性のある古いプロトコル（SSL, TLS 1.0/1.1）を無効化。
- ✓ **HSTS有効化:** 初回接続以降、ブラウザにHTTPS接続を強制するヘッダーを付与。

🌐 EDGE & LOAD BALANCER

CloudFront Policy

TLSv1.2_2021

Minimum Protocol Version

ALB Listener

ELBSecurityPolicy-TLS13-1-2-2021-06

HSTS Header: max-age=31536000

🏠 INTERNAL TRAFFIC (VPC)

🛡️ ALB → EKS (Backend)

Target GroupでHTTPS (443) を指定。Pod側で自己署名証明書または内部CA証明書により終端。

🗄️ EKS → Aurora

--ssl-mode=VERIFY_IDENTITY

RDS CAバンドルを使用してDB接続時にサーバー証明書を検証。

🚀 FUTURE ENHANCEMENT

暗号化対策（保存時）

データベース、ストレージ、および機密情報の包括的な保護戦略

📁 全レイヤーでの暗号化強制

医療データ（PHI）を含むすべての永続データに対し、AWS KMSを用いた強力な暗号化を適用。物理ディスクレベルでのデータ漏洩リスクを排除します。

- **Aurora & S3:** 業界標準のAES-256暗号化を強制し、未暗号化リソースの作成をポリシーで禁止。
- **Fargate:** エフェメラルストレージもプラットフォーム管理キーで透過的に暗号化。

🔑 鍵管理とライフサイクル

暗号鍵（CMK）の管理を厳格化し、コンプライアンス要件に準拠した運用を実現します。

- ✓ **自動ローテーション:** KMS CMKを1年ごとに自動更新し、万が一の鍵漏洩時の影響を最小化。
- ✓ **アクセス分離:** 鍵の使用権限と管理権限をIAMで明確に分離。

🗄️ AURORA MYSQL & S3 STORAGE

Aurora DB Cluster

Storage Encrypted: True

Backup Retention: 35 Days

S3 (ML Models)

SSE-KMS Encryption

Versioning: Enabled

📦 CONTAINER REGISTRY (ECR)

Image Protection

KMS Encryption

Vulnerability

🔍 Scan on Push

🏠 SECRETS MANAGER & KMS

DB Credentials

Auto Rotation: Enabled

KMS Key Policy

Rotation: 365 Days

📌 アプリケーションコードからハードコードされた認証情報を排除

IAM アクセス制御と権限管理

最小権限の原則、IRSAによるPod単位の制御、およびガードレール

🔑 最小権限と認証強化

「必要な時に、必要なリソースへ、必要な権限のみ」を付与するゼロトラスト原則を適用。管理者権限の濫用を防ぎ、職務分掌を徹底。

- **Least Privilege:** `AdministratorAccess` の使用を禁止。役割に応じた最小限のカスタムポリシーのみをアタッチ。
- **MFA強制:** マネジメントコンソールへのログインおよび特権的なAPI操作時には、多要素認証（MFA）を必須化。

🚧 統制とガードレール

個別の設定ミスを防ぐため、組織全体または境界レベルでの制限を適用し、セキュリティベースラインを維持。

- ✓ **SCP (Service Control Policies):** 組織レベルでルートユーザーの使用や、未承認リージョンでのリソース作成を禁止。
- ✓ **Permission Boundary:** 開発者が作成するIAMロールに対し、権限昇格を防ぐための最大権限境界を設定。

📦 IRSA (IAM ROLES FOR SERVICE ACCOUNTS)

Node共通の権限ではなく、**Pod単位**で個別のIAMロールを割り当て。

Pod SA → OIDC Provider → Assume Role → AWS S3/RDS

</> SCOPED POLICY EXAMPLES

S3 Read-Only (Specific Bucket)

```
{ "Action": ["s3:GetObject"], "Resource": ["arn:aws:s3:::ml-models/*"] }
```

Aurora DB Connect (IAM Auth)

```
{ "Action": ["rds-db:connect"], "Resource": ["arn:aws:rds-db:ap-ne-1:123:dbuser:*/ml_user"] }
```

🔑 CREDENTIAL MANAGEMENT

🔒 Secrets Manager Integration

DBパスワード等の機密情報は環境変数に平文で持たず、Secrets Store CSI Driver経由

監査ログ・監視体制

全レイヤーの可視化とリアルタイム脅威検知によるセキュリティ運用

完全な証跡記録

「いつ・誰が・何をしたか」を特定するため、AWSリソースへの全APIコールとネットワークトラフィックを記録・保管。

- **CloudTrail:** 全リージョン・全アカウントで有効化。ログファイルの整合性検証（改ざん検知）を有効にし、S3へ長期保存。
- **VPC Flow Logs:** 全ENI（Elastic Network Interface）を対象にトラフィックを記録し、不審な通信の分析基盤を確立。

脅威検知とコンプライアンス

インテリジェントな脅威検知サービスと統合監視ダッシュボードにより、セキュリティインシデントへの即応体制を整備。

- ✓ **GuardDuty:** 機械学習を活用して異常なAPI操作や通信パターン（C2通信、ポートスキャン等）を自動検知。
- ✓ **Security Hub:** AWS基礎セキュリティのベストプラクティス（FSBP）やPCI DSS等への準拠状況をスコア化。

COMPREHENSIVE LOGGING

 CloudTrail	Multi-Region / Integrity Check
 VPC Flow Logs	All Traffic / CloudWatch Logs
 EKS Control Plane	api, audit, authenticator

REAL-TIME MONITORING

CloudWatch - システムメトリクス - ロググループ集約 - アラーム通知 (SNS)	GuardDuty - 脅威インテリジェンス - 異常行動検知 - 自動アーカイブ
---	--

DATABASE AUDITING (AURORA)

 Advanced Audit Logs クエリログ、スロークエリログ、およびログイン試行を記録し、CloudWatch Logsへエクスポート。
--

医療データコンプライアンス

3省2ガイドライン準拠とBCP/DR対策

3省2ガイドライン対応

医療情報システムとして遵守すべき3つのガイドラインに準拠したアーキテクチャ設計。

厚生労働省

安全管理ガイドライン

経済産業省

情報処理事業者ガイド
ライン

総務省

ASP・SaaSガイドライ
ン

役割分離と権限管理

開発者と運用者の権限を明確に分離し、本番環境へのアクセスを厳格に制限。定期的な権限棚卸しを実施。

- ✓ 運用操作はIAMロールによる一時的な権限付与のみ。
- ✓ 鍵管理（KMS）担当者とデータアクセス者を分離。

監査ログ記録・保管



長期保管要件: 3年以上

S3 Object Lock（WORM）を使用し、改ざん不能な状態で全ログを保管。

対象ログ

CloudTrail, EKS Audit, Aurora Audit, VPC Flow Logs

暗号化と鍵管理

保存時暗号化

AWS KMS (CMK) を使用し、サービスごとに鍵を分離。

転送時暗号化

TLS 1.2以上を強制。内部通信も暗号化。

BCP / DR 対策

構成

Multi-AZ (3AZ)

RTO (目標復旧時間)

4時間以内

RPO (目標復旧時点)

1時間以内

コンテナセキュリティ

EKS/Fargateにおけるサプライチェーンとランタイム保護

III サプライチェーンセキュリティ

ビルドからデプロイまでの信頼チェーンを確立。脆弱なイメージの混入を防ぎ、署名検証により改ざんを防止します。

- **イメージスキャン & SLA:** ECRプッシュ時に自動スキャンし、Criticalな脆弱性は24時間以内に修正・置換。
- **署名と検証:** Sigstore/cosignを使用し、承認されたビルドパイプライン経由のイメージのみデプロイを許可。

🛡️ ランタイム防御とポリシー強制

実行中のコンテナに対する厳格な制限と、秘密情報のセキュアな注入メカニズムを実装。

- ✓ **Pod Security:** 特権コンテナやホストリソースへのアクセスを「Restricted」レベルで強制的にブロック。
- ✓ **秘密情報管理:** 環境変数を使用せず、CSI Driver経由でインメモリボリュームとしてマウント。

📦 SECURE REGISTRY (ECR)

Vulnerability Scan

Enhanced Scanning (Inspector)

Tag Immutability

Enabled

🔗 POLICY ENFORCEMENT

Pod Security Admission (PSA)

namespace: enforce=restricted

特権昇格の禁止、Root実行の禁止

Network Policy

Default Deny All Ingress/Egress

ホワイトリスト形式で通信を許可

Admission Controller

OPA Gatekeeper / Kyverno

インシデント対応フロー (IR Process)

検知から事後対応まで、NIST SP800-61準拠の6段階プロセスフロー



セキュリティ実装チェックリスト

CURRENT SCORE

85%




Edge & Network

☒

WAF: マネージドルール + レート制限(1000/5m)適用済

☒

TLS: CloudFront/ALBでTLS 1.2以上を強制、HSTS有効化

☒

SG/NACL: 最小権限原則、MySQL(3306)はEKS SGのみ許可


Compute (EKS)

☒

IRSA: Pod単位の最小権限、ECR PullとS3読取のみ

☐

Container: ECRイメージスキャン有効、脆弱性検知フロー確立

☐

NetworkPolicy: Pod間通信の明示的な許可ルール設定


Data Protection

☒

S3: SSE-KMS暗号化、パブリックアクセスブロック、バージョニング

☒

Aurora: KMS(CMK)暗号化、TLS接続必須、自動バックアップ(35日)

☒

Key Management: CMKの自動ローテーション有効化、職務分掌


Compliance

☒

3省2ガイドライン: 監査ログ3年保存、アクセス制御台帳の整備

☐

DR対策: RTO/RPO定義済、定期的な復旧リハーサルの実施


Monitoring & Audit

☒

CloudTrail: 全リージョン有効化、ログファイルの整合性検証ON

☒

Flow Logs: 全VPCトラフィックをCloudWatch Logsへ転送

☒

Audit Logs: EKS監査ログ(api, audit)およびAurora監査ログ有効化

Threat Detection

☒

GuardDuty: 全アカウントで有効化、SNS通知設定済

☒

Security Hub: 基礎的セキュリティのベストプラクティス標準有効化

☐

Alerting: CriticalアラートのPagerDuty連携とエスケーレーション

まとめ・今後のロードマップ

セキュリティレベルを段階的に強化するためのアクションプラン

短期 (0-1ヶ月)



- ✓ **WAFモード切替**
Countモードでの誤検知検証を完了し、Blockモードへ移行。
- ✓ **ポリシー棚卸し**
既存SG/IAM権限のレビューと不要ルールの削除。
- ✓ **ログ検証**
CloudTrail/Flow Logsの保存設定とAthenaクエリの準備。

中期 (1-3ヶ月)



- ✓ **NetworkPolicy適用**
EKS Pod間の通信制御をNamespace単位で厳格化。
- ✓ **OPA/Gatekeeper導入**
KubernetesアドミSSION制御によるポリシー強制。
- ✓ **Configルール展開**
AWS Configによる構成変更の継続的監査。

長期 (3-6ヶ月)



- ✓ **Service Mesh (mTLS)**
App Mesh/Istio導入によるマイクロサービス間通信の完全暗号化。
- ✓ **攻撃演習**
ペネトレーションテストおよび机上訓練(Tabletop Exercise)の定期化。
- ✓ **自動是正**
Security Hub + EventBridgeによる不適合設定の自動修復。

🔗 DevSecOps & Governance

インフラのコード化(IaC)とCI/CDパイプラインへのセキュリティテスト統合により、シフトレフトを実現。

</> IaC Scanning

🛠️ Auto-Remediation

👥 Access Review